

# Harden your service & control access

## Session 7 – Hardening & access control

Exercise 7 · Session 7 lab · Estimated time: 90–120 min

---

Write your answers in the answer document `SKY2100_Exercise7_Answers.docx`. Last week you put Nextcloud behind HTTPS. The service is encrypted but still exposed: default settings, an open SSH port, a single admin account. Today you shrink the attack surface and decide who may get in. You will reduce running services, lock down the firewall and SSH, add brute-force protection, and apply least privilege inside the app.

**Caution:** Work only on your own VM. Before you disable SSH password login, make sure key-based login already works in a second terminal – so you cannot lock yourself out.

### 1 Map the attack surface

---

- ▷ List everything that is listening on your VM and who owns each port:

```
ss -tulpn
```

- ▷ Which ports are exposed, and which do you actually need for an HTTPS Nextcloud you administer over SSH? Mark any you can switch off.

### 2 Default-deny firewall (UFW)

---

- ▷ Configure UFW to deny everything inbound, then allow only what you need:

```
sudo ufw -force reset # start clean: the S4 rules (22 and 80 open to all)
would otherwise stay
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 443/tcp
sudo ufw allow from <your-ip> to any port 22
sudo ufw enable && sudo ufw status verbose
```

- ▷ Why is “default deny, then allow” safer than “allow the bad ports”? (one or two lines)

### 3 Harden SSH

---

- ▷ Set up key-based login (if not already), then in `/etc/ssh/sshd_config` set:

```
PasswordAuthentication no
PermitRootLogin no
```

Reload with `sudo systemctl reload ssh`. **Keep your current session open** and confirm a new key-based login works before closing it.

- ▷ Why disable password authentication and root login specifically? Link each to a threat.

### 4 Brute-force protection (fail2ban)

---

- ▷ Install and enable fail2ban for SSH:

```
sudo apt install -y fail2ban
sudo systemctl enable -now fail2ban
sudo fail2ban-client status sshd
```

- ▷ Trigger a few failed logins from another machine/IP, then check the jail again. What changed?

## 5 Least privilege inside the app

---

- ▷ In Nextcloud, create a non-admin user and give it only the access it needs. Do not use the admin account for everyday work.
- ▷ Enable two-factor authentication (2FA) on the admin account.
- ▷ State one thing the admin can do that your new user cannot – and why that is least privilege.

## 6 Cloud transfer: Microsoft Learn

---

- ▷ Work through “Secure your Azure resources with Azure role-based access control (Azure RBAC)”. [learn.microsoft.com/training/modules/secure-azure-resources-with-rbac](https://learn.microsoft.com/training/modules/secure-azure-resources-with-rbac)
- ▷ In Azure RBAC you assign a **role** to an **identity** at a **scope**. Name the four scope levels from broadest to narrowest, and say which you would choose for least privilege.

## 7 Azure reflection

---

- ▷ Your UFW rules protect one VM. Which Azure construct enforces the same default-deny idea across your cloud resources, and at which layer (host vs. network)?
- ▷ CSA calls IAM “the new perimeter”. In your own words, why does identity matter more in the cloud than the network perimeter did on-premises?

**AHA.** Last week the service was encrypted, yet today you still had work to do: an open SSH port, a single all-powerful admin, default settings. Encryption did not make the service safe, because reachability and access are separate problems from confidentiality on the wire. Notice where the real boundary sits now. On-premises you could draw a line around the building and trust what was inside, but your cloud service has no inside; anyone who reaches it is judged by who they are, not where they connect from. That is why identity is the new perimeter, and why least privilege, MFA and a locked-down SSH matter more than any network wall.

## 8 Knowledge check

---

1. Define **attack surface** and give two ways hardening reduces it.  
**Hint:** Every point an attacker could enter or extract data — hardening shrinks it.
2. Why can a cloud tenant not rely on traditional perimeter security? (Comer)  
**Hint:** You share physical servers and links with other tenants — no hard perimeter.
3. State the difference between **authentication** and **authorisation**.  
**Hint:** One proves who you are; one decides what you may do.
4. Name the three authentication factors and say what **MFA** combines.  
**Hint:** Something you know, have, are — and combining two different ones.
5. Distinguish **RBAC** from **ABAC** with one example each.  
**Hint:** Permissions by role, versus permissions by attributes and conditions.
6. State the **principle of least privilege** in one sentence.

**Hint:** The minimum access an identity needs, and nothing more.

7. CSA defines an **entitlement** as a rule over which four things?

**Hint:** A rule: which entity, which actions, which resources, under which conditions.

8. What does **zero trust** mean for how each request is handled?

**Hint:** Trust nothing by default; verify every request instead of a one-time gate.

9. What is **single sign-on (SSO)**, and what problem does it solve?

**Hint:** One login across services from a central identity system — no password sprawl.

10. What is **PAM**, and why are privileged accounts treated specially?

**Hint:** Identity for admin accounts, which can do the most damage if taken.

11. In Azure RBAC, what three things make up a role assignment?

**Hint:** Identity, role, and the scope it applies to.

12. Name two **common cloud access-control mistakes** and the fix for each.

**Hint:** Admin roles without MFA, long-lived static keys, over-broad roles.

---

**Progress check:** Discuss your answers in the group, then talk the teacher through them verbally at the next session only to track progress; nothing is handed in, signed or graded.

---

## Solutions

Work through the lab first, then check here. Model answers are indicative — equivalent reasoning is fine.

**Note:** Model answers are indicative – accept equivalent reasoning. Multiple-choice answers are in **bold**.

### Knowledge check

---

1. The **attack surface** is the sum of all points where an attacker could try to enter or extract data – open ports, services, accounts, APIs, dependencies. Hardening reduces it by, e.g., removing unused services/packages and closing ports (default-deny firewall).
2. In the cloud, VMs and containers share physical servers and links with other tenants, so attacks can arise from within the facility; there is no clear inside/outside, so traditional perimeter security cannot define the network boundary (Comer p. 236).
3. **Authentication** verifies who you are (identity of a user/process/device). **Authorisation** decides what you may do (access control via granted permissions). Authenticate first, then authorise (CSA p. 105).
4. Factors: **something you know** (password), **something you have** (phone/token), **something you are** (biometric). **MFA** combines two or more, so a stolen password alone is not enough.
5. **RBAC** attaches permissions to roles and assigns roles to users (e.g. “editor” → edit files). **ABAC** grants access based on attributes/conditions (e.g. only with MFA on, only from a managed device, only if a resource tag matches) (CSA p. 105).
6. **Least privilege**: give every identity the minimum access it needs to do its job, and no more (Comer p. 236–237; CSA p. 119).
7. An **entitlement** is a rule: this **entity** may perform **these actions** on **these resources** under **these conditions** (with these attributes) (CSA p. 119).
8. **Zero trust**: trust nothing by default; validate every request using identity (and attributes/risk), instead of granting blanket access after a single login (Comer p. 237; CSA p. 120).
9. **Single sign-on (SSO)**: one set of credentials for all services via a central identity system; it solves the problem of separate logins per service and lets a user authenticate once per task (Comer p. 238).
10. **PAM (Privileged Access Management)** handles identity for administrative/superuser accounts. They are treated specially because forging one lets an attacker cause serious damage; PAM limits each admin to the systems they manage and logs all (and failed) accesses (Comer p. 238–239).
11. A role assignment = an **identity** (user/group/service principal/managed identity) + a **role** (e.g. Reader, Contributor) + a **scope** (management group / subscription / resource group / resource).
12. Any two of: admin roles without MFA; long-lived static access keys; over-broad roles (Owner where Reader suffices); public-by-accident storage; management plane exposed with weak auth. Fix: enforce MFA; rotate/eliminate static secrets (use managed identities); apply least-privilege roles; close public access; restrict and protect the management plane (CSA p. 104, 120).

### Lab checkpoints

---

- **Surface:** `ss -tulpn` should show only what is needed (443 for HTTPS, 22 for SSH). Anything else – old test servers, databases bound to 0.0.0.0 – is a candidate to disable or bind to

localhost.

- **Firewall:** `ufw status verbose` must show default deny incoming plus explicit allows. “Default deny then allow” fails safe – an unforeseen service is blocked unless you opened it; “block the bad ports” fails open.
- **SSH:** key-based login works; `PasswordAuthentication no` defeats password guessing/brute force; `PermitRootLogin no` removes the highest-value target (use a normal user + `sudo`). Verify a new session before closing the old one.
- **fail2ban:** after a few failed attempts, `fail2ban-client status sshd` shows failed/ banned counts – continuous brute force becomes a few blocked tries. This is detection feeding response (Comer p. 238: record failed logins to track attackers).
- **App least privilege:** a non-admin user cannot change server settings, manage users, or install apps; admin has 2FA enabled. Everyday work should not use the admin account.

## Cloud transfer & reflection

---

- **RBAC scope (broadest→narrowest):** management group, subscription, resource group, resource. For least privilege, assign at the narrowest scope that still lets the task succeed.
- **Azure default-deny:** a **Network Security Group (NSG)** enforces allow/deny by port/ protocol/source at the network layer around resources (the host UFW works at the host layer). Both should be default-deny.
- **IAM as the new perimeter:** cloud consolidates data-centre controls into Internet-facing consoles and APIs protected mainly by identity; with no network wall, identity is what stands between an attacker and everything. CSA notes the vast majority of cloud-native breaches start with IAM failures (CSA p. 103–104).

## References

---

CSA Security Guidance v5, **Domain 5: Identity & Access Management** (p. 103–120, verified) and **Domain 7: Infrastructure & Networking** (p. 147–148, verified). Comer, The Cloud Computing Book, Ch. 17 – Cloud Security & Privacy: attack surface (p. 233–235), perimeter & zero trust (p. 236–237), Identity Management & SSO (p. 238), PAM (p. 238–239), verified. MS Learn: Secure your Azure resources with Azure RBAC (verified, June 2026) – role + identity + scope, with an activity log of RBAC changes.